MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 044 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · CONTINUOUS ATO

Continuous ATO Asks for What a Three-Year ATO Never Did

A continuous ATO (cATO) is not an ATO that never expires. What DoD's cATO memo and evaluation criteria demand instead - telemetry, gates, SBOMs.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

CATO · RMF · DEVSECOPS · CONTINUOUS-MONITORING · SOFTWARE-SUPPLY-CHAIN

Program engineers who hear "continuous ATO" for the first time tend to picture a familiar document with one field deleted: the same authorization package, the same assessment, minus the expiration date. That picture is comfortable, and it lets a program spend a year building a very good three-year ATO while calling the effort a cATO.

The Department never offered that trade. A continuous ATO (cATO) is a state a system earns on top of an existing ATO, approved by the DoD CISO, in which the Authorizing Official demonstrates three competencies: ongoing visibility inside the system boundary with robust continuous monitoring of RMF controls, the ability to conduct active cyber defense in real time, and adoption of an approved DevSecOps reference design. In return, the system stops being reauthorized on a calendar. The governing memo, signed on 2 February 2022 by David W. McKeown as DoD Senior Information Security Officer, is explicit that the cATO leaves the underlying ATO in place and changes only how that ATO gets reauthorized. A cATO has no expiration date, can be revoked for poor posture, a change in risk tolerance, or an incident, and a system that loses it falls back to the ATO it already held.

So the real question for a program office is not how long the authorization lasts. It is what kind of evidence the authorization runs on. We have argued elsewhere that RMF and CMMC share most of their evidence; this piece stays inside RMF, where the shift from a point-in-time package to a live feed is the whole story.

A three-year ATO had a clock. A continuous ATO has a threshold

The three-year term was once written down plainly. The 2014 edition of DoDI 8510.01 required every ATO to carry an authorization termination date within three years, tracking the triennial reauthorization that OMB Circular A-130 then demanded, and it already carved out an exception for systems with a compliant system-level continuous monitoring program. The exception was the future; the calendar was the practice.

Policy moved first. OMB's 2016 revision of A-130 dropped the fixed cycle, directing agencies to move eligible systems to ongoing authorization and reauthorize on a time- or event-driven basis. NIST SP 800-37 Revision 2, published in December 2018, made ongoing authorization a named task (M-6) and noted that under it, reauthorization becomes in most cases an event-driven action rather than a scheduled one. The July 2022 reissue of DoDI 8510.01, approved by DoD CIO John Sherman, adopts that task table and no longer prints a three-year cap at all.

Practice lagged. A May 2025 Naval Postgraduate School acquisition-research paper, describing Air Force process, still puts recertification at every three years or after a major change, with initial approvals running six to 18 months. That lag is the business problem cATO was built to attack. A calendar authorization lets risk accumulate quietly between signatures, then prices the catch-up as a project with its own staffing surge and its own schedule slip. A threshold authorization spends the same money continuously and asks the AO to act the moment posture crosses an agreed line.

FIELD COPY
ISSUE Nº 044
CATO

3 years

THE LONGEST ATO TERM THE 2014 DODI 8510.01 ALLOWED WITHOUT A COMPLIANT CONTINUOUS MONITORING PROGRAM - A NUMBER THE 2022 REISSUE NO LONGER PRINTS

0

EXPIRATION DATES ON A DOD CISO-APPROVED CATO, WHICH LASTS ONLY AS LONG AS THE REAL-TIME RISK POSTURE HOLDS

90 days

THE WINDOW FOR A QUALIFIED THIRD-PARTY PENETRATION TEST OF DEVELOPMENT AND OPERATIONAL ENVIRONMENTS UNDER THE 2024 CATO CRITERIA, THEN ANNUALLY

The package was the product. The pipeline is the product

DoD CIO dated its cATO Evaluation Criteria for the DevSecOps use case 29 May 2024, alongside an April 2024 implementation guide. The criteria are candid that cATO moves away from a solely document-based, point-in-time approach while some point-in-time documents are still required. The familiar package does not disappear: the Security Assessment Plan, Security Assessment Report, Risk Assessment Report, SSP, signed ATO memo, and POA&Ms are pulled from the Component's RMF inventory tool, which for many programs means eMASS. What changes is that those documents become the floor rather than the deliverable.

Above the floor, the criteria ask for things no traditional package ever contained. A continuous monitoring strategy with explicit timelines per control, automated ones measured in hours, minutes, or seconds and manual ones on their own stated cadence. A live demonstration of a system-level dashboard showing which controls feed it. Automated compliance reporting to the Continuous Monitoring and Risk Scoring system where possible. A software bill of materials for the DevSecOps platform itself, an automated SBOM export for every application that passes through it, an archive of those SBOMs, and a written account of what happens to them when a new CVE lands. A description of every pipeline control gate, what opens and closes it, and a demonstration of each one firing. Reliance on infrastructure and configuration as code, so the environment cannot drift away from what was assessed.

◆ WHO SAYS YES, FOR NOW

The 2024 evaluation criteria place cATO approval with the **DoD CISO**, with a stated plan to delegate it to Component CISOs once the criteria are standardized for the DevSecOps use case. Until then, every request climbs to the Department level - one more reason the package has to be complete the first time.

A three-year ATO asks whether the system was secure when someone looked. A cATO asks whether you can show it is secure right now, without anyone having to go look.

In the old world, the SAR was the product and the pipeline was an engineering detail. In the new one, the pipeline and its telemetry are the evidence, and the SAR is a snapshot of something the AO can already watch.

The assessor visited. The defenders stay

Active cyber defense is the competency easiest to underestimate, because it sounds like something vulnerability management already covers. The memo closes that door directly: "Simply conducting scans and patching does not meet the threshold for active cyber defense." What it wants instead is a demonstrated ability to deploy countermeasures in real or near real time, with the AO in constant contact with the Cybersecurity Service Provider, component cyber forces, JFHQ-DoDIN, and US Cyber Command.

The 2024 criteria turn that into artifacts. A certified CSSP under DoDI 8530.01 with a service-level agreement covering on-premises and cloud systems. A penetration test of development and operational environments by a qualified third party within 90 days and annually after, in one of the AO-approved forms. Cloud-hosted environments carry a cloud-native application protection platform requirement spanning artifact scanning, posture management, and runtime protection. The people are assessed too: role-based training on the control gates and risk tolerances, periodic tabletop exercises with after-action reports, and an insider threat working group chaired by senior leadership. And the monitoring loop has teeth. When an anomaly exceeds the agreed thresholds, the CSSP or Security Control Assessor can trigger a cATO review, and the CISO decides whether to revoke.

Inherited on paper. Inherited in the feed

The criteria set the entry bar before any of that is weighed: a system must already sit in the RMF Monitor step with a current ATO and no unmitigated High or Very High findings. Programs that clear it are likeliest to stall in three places the criteria make visible.

The first is control inheritance. The memo requires continuous monitoring of all controls in the baseline, common controls included. A traditional package can mark a control inherited from a hosting provider or enterprise service and point to a matrix. A cATO needs that inherited control's status arriving in the AO's dashboard, which means someone outside the program has to be feeding it. The second is tool sprawl. Scanners, code analysis tools, and cloud posture consoles each report in their own format; the criteria ask for one real-time view, and aggregation is work that rarely makes the budget. The third is the quiet one: control status that is still set by hand, once, when the package is due. A dashboard fed by manual attestation is a three-year ATO with better graphics.

Scope matters as well. These criteria are written for software factories, with a second use case for factories deploying into another authorization boundary through a memorandum of understanding and an interconnection security agreement. A program with no DevSecOps platform under it is not a cATO candidate yet, however good its monitoring.

The same instinct, a control's status as a feed rather than a memory, runs through MacTech's EnclaveWatch, which validates a CUI vault's posture continuously, though that is a different regime and not a cATO. For programs still running on the calendar, the RMF implementation guide and the continuous monitoring

program design described in our capabilities statement are where that work starts.

The honest readiness test takes an afternoon. Beside each control in today's continuous monitoring strategy, write the data source that reports its status and how often it reports. Every blank line is a control your AO can only learn about by asking a person, and a cATO is precisely the promise that nobody will have to ask. ◆

MORE ISSUES

mactechsolutionsllc.com/maczine
new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF
mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.
Published from Git, reviewed like code.